로직 고도화 재검증 보고서

독립 메뉴 10개와 화면 배치를 유지한 0.44.0 → 0.45.0 개선 결과

기존에 실패한 5개 항목을 모두 통과했습니다.

같은 개인용 로컬 Juice Shop에서 계정 판정, JS/API 분석, SQLite 오류 탐지와 저장 후 조회 연결을 다시 확인했습니다. 메뉴·배치 소스 5개는 이전 버전과 동일합니다.

검증 구분	이전 0.44.0	개선 0.45.0
실제 Burp 기능 조건	28 / 33 충족	33 / 33 충족
실제 Chromium 흐름	5 / 5 통과	5 / 5 통과
별도 회귀·HTTP 검사	2,890개 통과	2,942개 통과

무엇이 달라졌나요?

항목	이전 문제	개선 결과
AU-08 차단 규칙	대상 차단 문구가 있어도 400 응답 2칸 보류	규칙과 일치하고 자료 충돌이 없으면 차단 근거로 분류
JS-02 대표 API	실제 main.js의 대표 API 3개 미발견	로그인·장바구니·검색 경로 3개 모두 발견
RE-02 DB 오류	SQLITE_ERROR 누락	응답 분석에서 SQLite 오류 후보 탐지
RE-03 저장 흐름	POST 302 뒤 조회 원본 미연결	같은 Origin의 조회·마커를 후보 흐름으로 연결
PL-01 입력 검사	기본 SQL 검사에서 SQL 후보 미분류	공통 DB 오류 패턴과 문맥별 조건 쌍 보완

기능 조건의 통과는 모든 취약점에 대한 정확도를 뜻하지 않습니다. 33개 기능 조건, 브라우저 5개와 회귀 2,942개는 서로 다른 검사이므로 정확도로 합산하지 않습니다.

10개 기능의 확인 결과

계정 권한 비교 외의 기능도 같은 실제 Burp 실행에서 확인했습니다.

기능	조건 충족	이번에 확인한 범위
요청·응답 목록	4 / 4	OFF/SCOPE, 다른 포트 제외, 원본 수집
계정 권한 비교	8 / 8	권한표, 빈 사용자 응답, 대상 차단 규칙
데이터 변환·비교	3 / 3	JWT 읽기, 한글 변환, 응답 비교·원본 연결
JS에서 API 찾기	3 / 3	대표 API 3개, 보관 버전의 전체 분석 실패 제외
서버·경로 탐색	2 / 2	실재 경로와 가짜 200 공통 화면 구분
URL 후보 수집	2 / 2	History·JS 수집, 선택한 URL의 GET 확인
점검 진행 현황	2 / 2	수동 완료·재검토·저장 후 복원
응답 보안 분석	4 / 4	헤더·SQLite 오류·302 및 2xx 저장 흐름
입력값 보안 검사	3 / 3	기본 SQL 후보·맞춤 참/거짓·내장 패널
재현·증거 정리	2 / 2	2단계 재현·원본 연결·인증값 가림 ZIP

메뉴와 배치를 유지한 근거

FeatureGuide, FolderNavigation, AuthLayout, WorkbenchExtension, LayoutSettings 소스의 SHA-256을 기준 버전과 대조했습니다. 5개 모두 같습니다. JS·응답 분석 패널의 분석 처리와 상태 문구는 개선했으며 화면 구조는 유지했습니다.

헤드리스 Swing 배치 검사에서는 150개 화면을 렌더링했습니다. 2,640개 컨트롤·탭/제목 측정에서 잘림, 최소 크기 위반과 핵심 영역 붕괴가 없었습니다. 실제 Burp GUI 수동 클릭이나 운영체제별 DPI 확인과는 별도입니다.

정탐·오탐·미탐·보류의 이유

기본 규칙과 대상 전용 규칙을 적용한 재검사를 분리했습니다.

집계	기본 규칙 이전 → 개선	대상 규칙 이전 → 개선
정탐 TP	6 → 6	0 → 0
오탐 FP	1 → 0	0 → 0
미탐 FN	0 → 0	0 → 0
정상 판단 TN	9 → 9	4 → 6
보류 REVIEW	2 → 3	2 → 0
대조 칸 수	18칸	6칸 재검사

기본 규칙의 보류가 1건 늘어난 이유

비로그인 신원 조회는 HTTP 200과 {"user":{}}를 반환합니다. 실제 사용자 정보가 없으므로 우회 의심으로 표시하던 오탐 1건을 확인 필요로 바꿨습니다. 빈 응답만으로 정상 차단까지 확정하지 않습니다.

분류	사유
정탐 6건	사용자 목록 2칸과 타인 장바구니 4칸에서 금지한 접근의 실제 데이터가 관측됐습니다. 관리자도 타인 장바구니는 차단하도록 정한 실습 권한표 기준입니다.
오탐 0건	이전 빈 user 객체를 취약점으로 표시한 1건을 보류로 바꿨습니다. 다른 서비스의 오탐 0을 보장하는 수치는 아닙니다.
미탐 0건	이번 권한표에서 실제 노출을 확인한 6칸이 모두 우회 의심으로 표시됐습니다. REVIEW 3칸은 FN/TN으로 중복 집계하지 않습니다.
보류 3건	기본 규칙에서는 주소 조회의 HTTP 400 2칸과 빈 사용자 200 응답 1칸에 차단 또는 접근 성공을 확정할 근거가 부족합니다.

대상 규칙을 지정하면: 빈 user 객체와 정확한 거부 문구에 맞춘 규칙으로 6칸을 다시 검사해 TN 6, 보류 0을 확인했습니다. 기준 계정은 기본 6칸·추가 2칸을 제외했습니다. 재검사 6칸을 새로운 독립 사례로 합산하지 않습니다.

분석 결과를 읽는 방법

후보 발견, 서버 저장, 브라우저 실행을 구분하면 판단 근거가 선명해집니다.

JS/API: 발견 후보를 보존합니다

대표 경로	최종 결과
/rest/user/login	발견
/rest/basket/	발견
/rest/products/search	발견

실제 약 1.24MB main.js의 보관 버전 2개에서 각각 API 후보 62개를 확인했습니다. Angular·템플릿 호출을 보조 복구하고 잘못된 문자열 하나로 전체 후보가 사라지지 않게 했습니다. 전체 분석 실패는 0개였지만, 문맥 미확정 구간 2개와 미확정 값은 남습니다. 대표 경로 3개 발견을 전체 API 누락 0으로 해석하지 않습니다.

SQL: 오류와 조건 차이를 후보로 제시합니다

SQLite·Sequelize 오류 인식을 응답 분석과 입력 검사에서 공유합니다. 기본 검사 12회와 대상 문맥 참·거짓 대조 4회를 확인했습니다. 기존 기준 응답에도 있던 오류와 단순 문자열 반사는 새 SQL 주입 근거로 사용하지 않습니다.

LIKE·닫는 괄호 문맥의 검사값 4개를 추가했습니다. 요청 예산과 중단 제어는 유지합니다. 오류·조건 차이만으로 SQL 주입을 확정하지 않고 원본 응답과 재현 근거를 확인해야 합니다.

저장 흐름: 리다이렉트 뒤 조회를 연결합니다

흐름	확인된 사실	유지하는 한계
POST 302 → GET 200	관측한 같은 Origin의 대상·고유 마커와 조회 원본 연결	쓰기 2xx는 미관측. 서버 영구 저장·브라우저 실행 미확정
POST 201 → GET 200	기존 2xx 저장·조회 마커 연결 유지	2xx 응답과 재출력만으로 실행을 확정하지 않음

리다이렉트 분석은 이미 관측한 패킷을 연결합니다. 추가 HTTP 요청을 만들지 않으며 외부 Origin, 다른 후속 경로와 URL 자체의 마커 반사는 연결하지 않습니다.

검증 범위와 증거 확인

같은 작업에서 완료한 최종 실행 원본과 배포 파일의 소스·해시 일치를 확인했습니다.

구분	실제 실행 범위
대상	개인용 로컬 OWASP Juice Shop 20.3.0 · Node 24
Burp / Java	Burp Suite Community Edition 2026 3.3 / Java 21.0.8
브라우저	Chromium 146.0.7680.177 · 전용 Burp Proxy · 5개 흐름
수집	수신 170 · 저장 169 · 처리 오류/누락/큐 초과 0
회귀	2,442 + 페이로드 HTTP 132 + 전체 기능 HTTP 102 + 업무 흐름 266 = 2,942
추가 확인	패키징 6개, 배포 해시·소스 지문, 메뉴 소스 5개, 화면 배치 검사
종료·가림	테스트가 만든 Burp·Juice Shop 종료. 허용 목록 파일과 증거 ZIP에 테스트 원문 토큰 없음

확인하지 않은 범위

crAPI, 수동 Burp GUI 클릭, 실제 Oracle/Nginx, Windows DPI/IME, 외부 OAST·BApps·아카이브와 대규모 성능은 이번 로컬 실행 범위 밖입니다. 실제 Windows/Linux 검증은 PR의 원격 CI 기록을 별도로 확인합니다.

증거 읽는 순서

summary.json → checks.csv → account-results.csv 순서로 읽으세요. CSV는 계정별 정탐·오탐·미탐·보류와 판단 이유를 제공합니다. JSON, 해시 목록과 가림 ZIP은 같은 증거 묶음에 있습니다. 비밀번호·원문 토큰·개인 프로필·서버 로그·실습 DB는 제외했습니다.

배포 JAR SHA-256

7181be222604bfa5a6b0f735014f19973ef33b800c9922b8ea6d46b1a91be201

재현: audit/oss-lab/README_KR.md의 절차에서 --extension-version 0.45.0과 새 결과 폴더를 지정합니다. 전체 회귀·배포는 python dev.py release, 무결성은 python tools/package_downloads.py --verify로 확인합니다.